TẤN CÔNG HỆ THỐNG THÔNG TIN (LỖ HỔNG BẢO MẬT)

Signature Valid [V]

Signed by: Nguyen Van a
CCCD: 000000000002
Dept: IT
Date: 08:25:44 17/4/2026

Nội dung

1. Tổng quan về tấn HTTT
2. Các mô hình tấn công HTTT
3. Một số kỹ thuật tấn công HTTT
4. Lỗ hổng bảo mật

Tổng quan về tấn công HTTT

ĐỊNH NGHĨA

- ✓ Hiện nay vẫn chưa có định nghĩa chính xác về thuật ngữ "tấn công" (xâm nhập, công kích). Mỗi chuyên gia trong lĩnh vực ATTT luận giải thuật ngữ này theo ý hiểu của mình. Ví dụ, "xâm nhập - là tác động bất kỳ đưa hệ thống từ trạng thái an toàn vào tình trạng nguy hiểm".
- ✓ Thuật ngữ này có thể giải thích như sau: "xâm nhập - đó là sự phá huỷ chính sách ATTT" hoặc "là tác động bất kỳ dẫn đến việc phá huỷ tính toàn vẹn, tính bí mật, tính sẵn sàng của hệ thống và thông tin xử lý trong hệ thống".

Định nghĩa

- Tấn công (attack) là hoạt động có chủ ý của kẻ phạm tội lợi dụng các thương tổn của hệ thống thông tin và tiến hành phá vỡ tính sẵn sàng, tính toàn vẹn và tính bí mật của hệ thống thông tin.
- Hệ thống thông tin là tổng thể kết hợp giữa phần cứng, phần mềm và mạng truyền thông, nhằm thu thập, xử lý, lưu trữ và phân phối thông tin và dữ liệu hữu ích trong một tổ chức cụ thể.

Định nghĩa

- Tấn công (*attack, intrustion*) là các tác động hoặc là trình tự liên kết giữa các tác động với nhau để phá huỷ, dẫn đến việc hiện thực hoá các nguy cơ bằng cách lợi dụng đặc tính dễ bị tổn thương của các HTTT này.

Do đó nếu có thể bài trừ nguy cơ thương tổn của các hệ thông tin chính là trừ bỏ khả năng có thể thực hiện tấn công.

Một số phương thức tấn công

- Phân loại

1) Tấn công thăm dò.
2) Tấn công sử dụng mã độc.
3) Tấn công xâm nhập mạng.
4) Tấn công từ chối dịch vụ.

- Hoặc:

1) Tấn công chủ động.
2) Tấn công thụ động.

Một số khái niệm cơ bản

1. Người thực hiện tấn công

- Người thực hiện các tấn công mạng thường là những người có hiểu biết sâu sắc về giao thức TCP/IP, có hiểu biết về hệ điều hành, có thể sử dụng thành thạo một số ngôn ngữ lập trình.

- Các hướng tấn công:

  ✓ Tấn công từ bên trong mạng.

  ✓ Tấn công từ bên ngoài mạng.

Tấn công bên trong mạng

- *Tấn công không chủ ý*: Nhiều hư hại của mạng do người dùng trong mạng vô ý gây nên. Những người này có thể vô ý để hacker bên ngoài hệ thống lấy được password hoặc làm hỏng các tài nguyên của mạng do thiếu hiểu biết.
- *Tấn công có chủ ý*: Kẻ tấn có chủ ý chống lại các qui tắc, các qui định do các chính sách an ninh mạng đưa ra.

Tấn công từ ngoài mạng

- *Kẻ tấn công nghiệp dư (“script-kiddy”)*: Dùng các script đã tạo sẵn và có thể tạo nên các các thiệt hại đối với mạng.
- *Kẻ tấn công đích thực (“true- hacker”)*: Mục đích chính của nhóm người này khi thực hiện các tấn công mạng là để mọi người thừa nhận khả năng của họ và để được nổi tiếng.
- *Kẻ tấn công chuyên nghiệp (“the elite”)*: Thực hiện các tấn công mạng là để thu lợi bất chính.

Một số khái niệm cơ bản

2. Thời điểm thực hiện tấn công

- Bất kỳ.
- Thường thực hiện về đêm.

3. Hệ điều hành sử dụng để tấn công

- Bất kỳ.
- Thường sử dụng các HĐH mã nguồn mở.

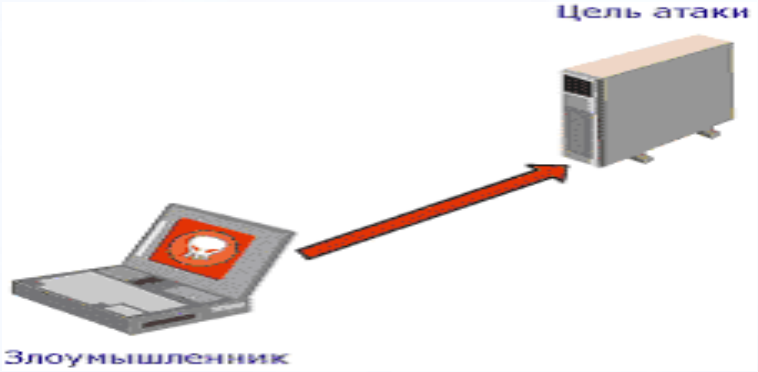
4. Các hệ thống mục tiêu

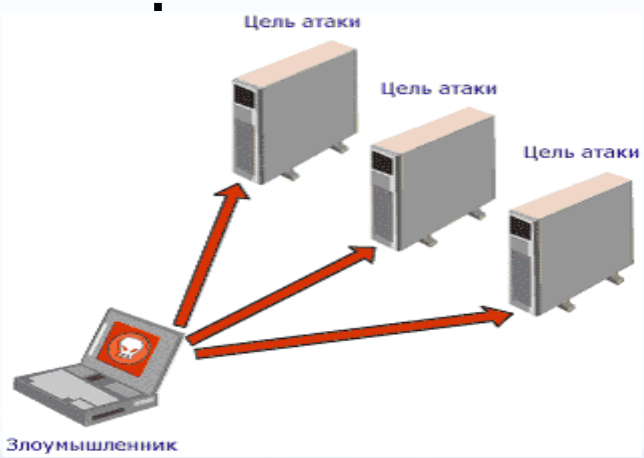
- Con người, phần cứng, phần mềm, dữ liệu, thông tin …

Các mô hình tấn công mạng

Mô hình tấn công truyền thống

- Mô hình tấn công truyền thống được tạo dựng theo nguyên tắc "một đến một" hoặc "một đến nhiều", có nghĩa là cuộc tấn công xảy ra từ một nguồn gốc.
- Mô tả: Tấn công "một đến một"

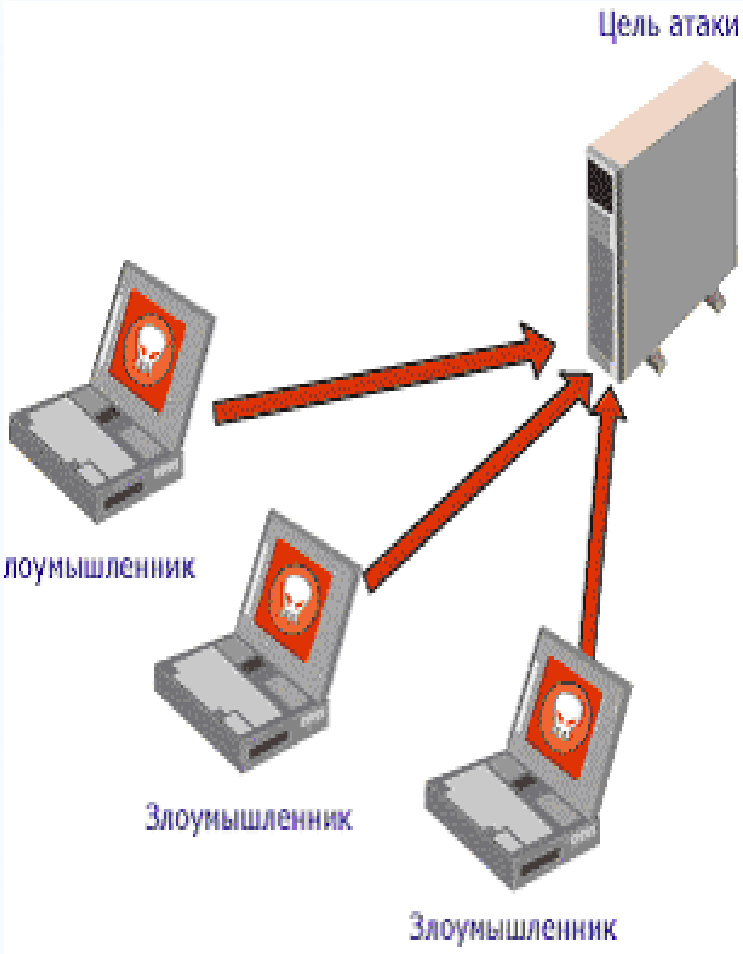


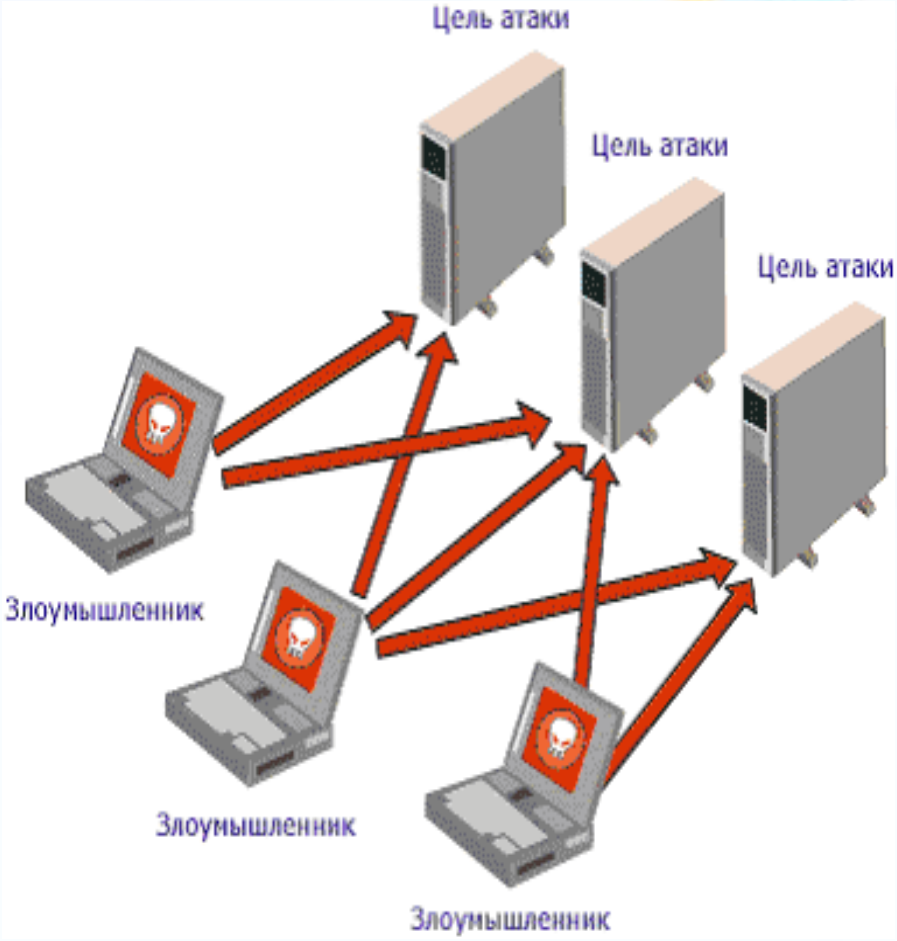


Mô hình tấn công phân tán

- Khác với mô hình truyền thống trong mô hình tấn công phân tán sử dụng quan hệ “nhiều đến một” và “nhiều đến nhiều”.
- Tấn công phân tán dựa trên các cuộc tấn công “cổ điển” thuộc nhóm “từ chối dịch vụ”, chính xác hơn là dựa trên các cuộc tấn công như Flood hay Storm (những thuật ngữ trên có thể hiểu tương đương như “bão”, “lũ lụt” hay “thác tràn”).

Mô hình tấn công phân tán





Các bước tấn công

Xác định mục tiêu

↓

Thu thập thông tin mục tiêu,
Trinh sát dò tìm lỗ hổng

↓

Lựa chọn mô hình tấn công

↓

Thực hiện tấn công

↓

Xóa dấu vết (nếu cần)

Một số kỹ thuật tấn công mạng

1) Tấn công thăm dò.
2) Tấn công sử dụng mã độc.
3) Tấn công xâm nhập mạng.
4) Tấn công từ chối dịch vụ.

Tấn công thăm dò

- Thăm dò là việc thu thập thông tin trái phép về tài nguyên, các lỗ hổng hoặc dịch vụ của hệ thống.
- Tấn công thăm dò thường bao gồm các hình thức:
  - Sniffing
  - Ping Sweep
  - Ports Scanning

Sniffing (Nghe lén)

- Sniffer là một hình thức nghe lén trên hệ thống mạng dựa trên những đặc điểm của cơ chế TCP/IP.
- Sniffer ban đầu là một kỹ thuật bảo mật, được phát triển nhằm giúp các nhà quản trị mạng khai thác mạng hiệu quả hơn, và có thể kiểm tra các dữ liệu ra vào mạng cũng như các dữ liệu trong mạng (kiểm tra lỗi).
- Sau này, hacker dùng phương pháp này để lấy cắp mật khẩu hay các thông tin nhạy cảm khác.
  - Biến thể của sniffer là các chương trình nghe lén bất hợp pháp như: công cụ nghe lén yahoo, ăn cắp password email…

Active sniffer

- Môi trường hoạt động: Chủ yếu hoạt động trên các mạng sử dụng thiết bị chuyển mạch (switch).
- Cơ chế hoạt động: Thay đổi đường đi của dòng dữ liệu, áp dụng cơ chế ARP và RARP (hai cơ chế chuyển đổi từ IP sang MAC và từ MAC sang IP) bằng cách phát đi các gói tin đầu độc.
- Đặc điểm: Do phải gửi gói tin đi nên chiếm băng thông của mạng, nếu sniff quá nhiều trong mạng thì lượng gói tin gửi đi sẽ rất lớn (do liên tục gửi đi các thông tin giả mạo) có thể dẫn tới nghẽn mạng hay gây quá tải lên chính NIC của máy (thắt nút cổ chai)

Active sniffer

- Một số kỹ thuật ép dòng dữ liệu đi qua NIC của mình như:
  - ARP poisoning: thay đổi thông tin ARP
  - MAC flooding: làm tràn bộ nhớ switch, từ đó switch sẽ chạy chế độ forwarding mà không chuyển mạch gói.
  - Giả MAC: các sniffer sẽ thay đổi MAC của mình thành một MAC của một máy hợp lệ và qua được chức năng lọc MAC của thiết bị.
  - Đầu độc DHCP để thay đổi gateway của máy client.
  - DNS spoofing: làm phân giải sai tên miền.

Passtive sniffer

- Môi trường hoạt động: Chủ yếu hoạt động trong môi trường không có thiết bị switch mà dùng hub.
- Cơ chế hoạt động: Hoạt động dựa trên cơ chế broadcast gói tin trong mạng; do không có thiết bị switch nên các các gói tin được broadcast đi trong mạng; có thể bắt các gói tin lại để xem (dù host nhận gói tin không phải là nơi gói tin đó gửi tới)
- Đặc điểm: Do máy tự broadcast gói tin nên hình thức Passtive sniff này rất khó phát hiện.

So sánh

- Acctive:
  - Môi trường mạng sử dụng switch.
  - Đầu độc ARP.
- Passive:
  - Môi trường mạng sử dụng hub.
  - Broadcast gói tin.
- **Một số công cụ sniffer**
  - Ettercap
  - Cain & Abel
  - HTTP sniffer
  - …

Phát hiện và phòng chống sniff

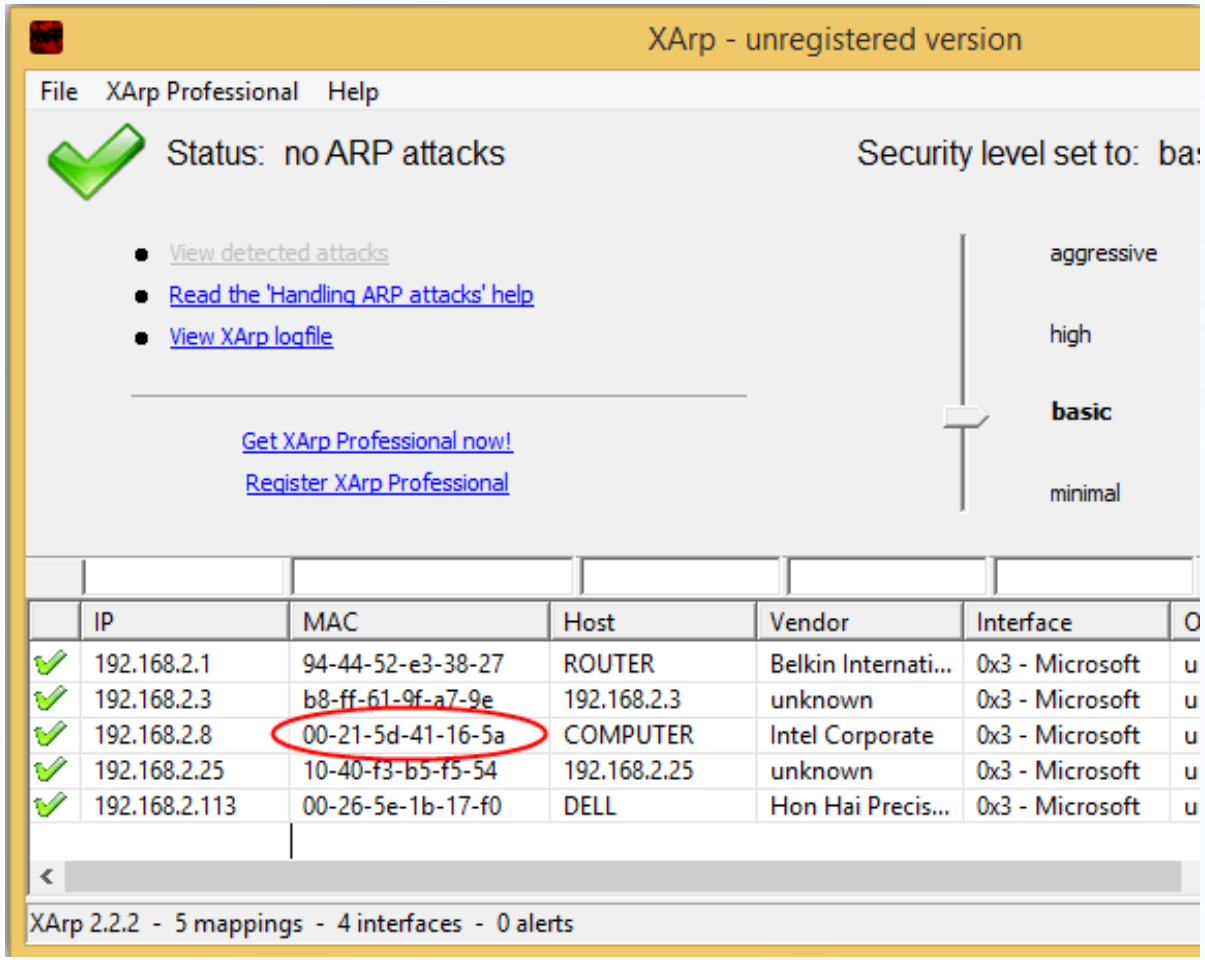
- Dựa vào quá trình đầu độc ARP của sniff để phát hiện:
  - Vì phải đầu độc ARP nên sniffer sẽ liên tục gửi gói tin đầu độc tới các victim. Do đó ta có thể dùng các công cụ bắt gói tin trong mạng để phát hiện
  - Một cách khác ta có thể kiểm tra bảng ARP của host. Nếu thấy trong bảng APR có 2 MAC giống nhau thì có thể mạng đang bị sniffer.

Phát hiện và phòng chống sniff

- Dựa trên băng thông:
  - Do quá trình gửi gói tin đầu độc của sniffer nên quá trình này có thể chiếm băng thông từ đây có thể dùng một số công cụ kiểm tra băng thông để phát hiện.
- Các công cụ phát hiện sniffer:
  - Xarp
  - ARPwatch
  - Simantec endpoint protection

Phát hiện và phòng chống sniff

- Các công cụ phát hiện sniffer:
  - Xarp:



Phát hiện và phòng chống sniff

- Các công cụ phát hiện sniffer:
  - ARPwatch

ARP Watch

IP-address: 192.168.0.232
MAC-address:
Filter!

Display period: all (0 seconds), IP = 192.168.0.232, MAC = all

Last hour only: IP-based MAC-based Top stats
Last day only (default): IP-based MAC-based Top stats
All: IP-based MAC-based Top stats

IP	What	MAC	Old MAC	Time	Old time	Delta
192.168.0.232						
	new station	2f:ca:ee:1e:38:b4		Tue Apr 15 14:10:35 2008		
	changed ethernet address	2f:ca:ee:e5:6e:d5	2f:ca:ee:1e:38:b4	Fri Apr 18 23:09:11 2008	Tue Apr 15 14:17:50 2008	291081 seconds
	changed ethernet address	2f:54:d:fc:c1:29	2f:ca:ee:e5:6e:d5	Sun Apr 20 16:23:30 2008	Fri Apr 18 23:10:24 2008	148386 seconds
	changed ethernet address	2f:9a:72:2e:2a:c6	2f:54:d:fc:c1:29	Fri Apr 25 12:01:31 2008	Sun Apr 20 16:23:32 2008	416279 seconds
	changed ethernet address	7c:c1:a1:c6:26:f8	2f:9a:72:2e:2a:c6	Mon Apr 28 20:14:06 2008	Fri Apr 25 12:01:37 2008	288749 seconds
	changed ethernet address	2f:ee:e0:b7:8e:72	7c:c1:a1:c6:26:f8	Tue Apr 29 08:21:45 2008	Mon Apr 28 20:14:37 2008	43628 seconds
	flip flop	7c:c1:a1:c6:26:f8	2f:ee:e0:b7:8e:72	Tue Apr 29 08:24:23 2008	Tue Apr 29 08:21:48 2008	155 seconds
	changed ethernet address	2f:3a:63:29:24:5b	7c:c1:a1:c6:26:f8	Wed May 7 18:02:53 2008	Tue Apr 29 08:24:24 2008	725909 seconds
	changed ethernet address	2f:54:9f:71:a1:fe	2f:3a:63:29:24:5b	Wed May 28 01:21:01 2008	Wed May 7 18:03:18 2008	1754263 seconds
	changed ethernet address	2f:e9:6c:e1:e5:18	2f:54:9f:71:a1:fe	Thu May 29 21:37:38 2008	Wed May 28 01:25:36 2008	159122 seconds
	changed ethernet address	2f:e7:a2:ca:17:ed	2f:e9:6c:e1:e5:18	Sun Jun 1 13:29:16 2008	Fri May 30 11:25:02 2008	180254 seconds
	changed ethernet address	2f:6:4f:a:f8:13	2f:e7:a2:ca:17:ed	Fri Jun 6 12:16:51 2008	Sun Jun 1 13:29:17 2008	427654 seconds
	new station	2f:ee:e0:b7:8e:72		Sat Jul 5 14:16:32 2008		
	changed ethernet address	2f:93:50:2e:b9:c2	2f:ee:e0:b7:8e:72	Mon Jul 7 08:44:57 2008	Sat Jul 5 14:16:35 2008	152902 seconds
	changed ethernet address	2f:ca:58:90:cb:3	2f:93:50:2e:b9:c2	Mon Jul 14 02:19:19 2008	Mon Jul 7 08:45:01 2008	581658 seconds

Phát hiện và phòng chống sniff

- Các công cụ phát hiện sniffer:
  - Simantec endpoint protection

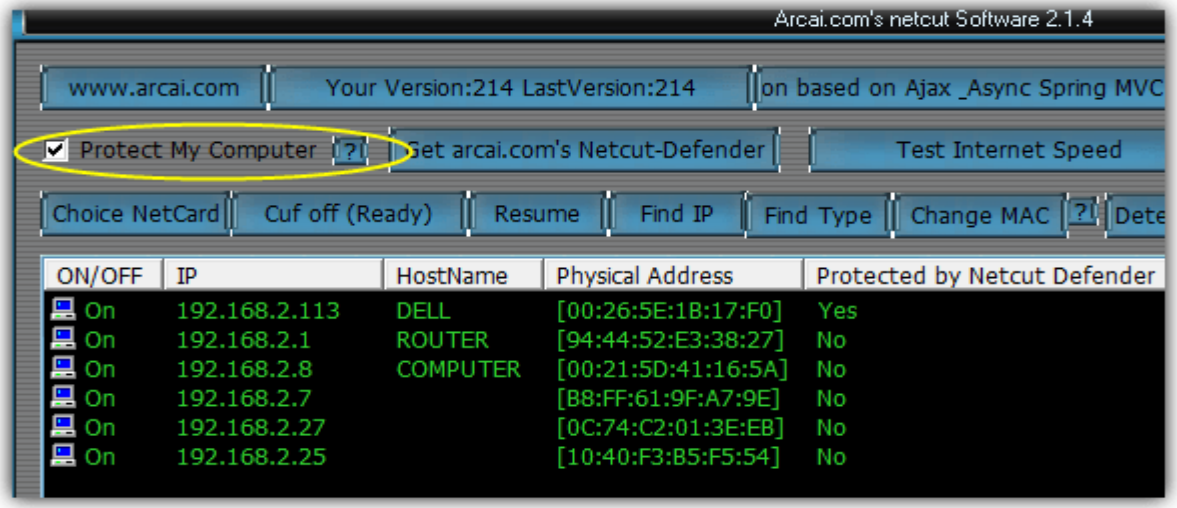
  - ArpCacheWatch, ArpWatcher …

Phát hiện và phòng chống sniff

- Các công cụ phát hiện sniffer:

NetCut

Ironically, the NetCut program that is used to cut off a person's Internet connection has an option to protect against the attack. Simply make sure that the "Protect My Computer" checkbox is ticked and this will ensure that your IP address is mapped to the correct MAC address.



Basically NetCut protects against its own attack by constantly sending packets to the gateway informing the router the correct mapping of the IP to MAC address. The router will be easily flooded with packets when NetCut is being used to attack and protect.

Phòng chống Active sniff

- Người quản trị:
  - Công cụ:
    - Kiểm tra băng thông.
    - Bắt các gói tin.
  - Thiết bị:
    - Dùng các loại thiết bị có chức năng lọc MAC.
    - Với mạng switch có thể dùng thêm chức năng VLAN trunking, kết hợp thêm chức năng port security (tương đối hiệu quả trong mô hình mạng VLAN và kết hợp thêm tính bảo mật).
- Người dùng:
  - Sử dụng ARP dạng tĩnh.
  - Dùng các công cụ phát hiện sniffer để cảnh báo cho người dùng.

Phòng chống Passive sniff

- Dạng sniff này khó phát hiện cũng như phòng chống.
- Thay hub bằng switch lúc đó các gói tin không còn broadcast nữa.

SCANNING

- Quá trình Scanning thực chất là tiếp tục quá trình thu tập thông tin về hệ thống nhưng lúc này hacker đã tác động trực tiếp đến máy chủ mà hacker cần tấn công.
- **Ping Sweep**
- **Port Sanning (TCP Scan, *SYN, XMAS, FIN, NULL, IDLE Scan)***

SCANNING

- Xác định hệ thống có đang “sống” hay không ?
- B1: Kiểm tra các port nào đang mở
- B2 Xác định những dịch vụ nào đang chạy tương ứng với cổng đang mở
- B3 Xác định dịch vụ và hệ điều hành và phiên bản của nó
- B4 Kiểm tra lỗi của những dịch vụ đang chạy
- B5 Xây dựng sơ đồ những host bị lỗi
- B6 Chuẩn bị một proxy tốt và tấn công.

Ping sweep

- Ping: Đưa ra một gói yêu cầu ICMP và đợi trả một thông báo trả lời từ một máy hoạt động.
- Ping Sweep: Xác định hệ thống đang "sống" hay không; rất quan trọng vì có thể hacker ngừng ngay tấn công khi xác định hệ thống đó đã "chết". Việc xác định trạng thái hệ thống có thể sử dụng kỹ thuật Ping Scan hay còn gọi với tên Ping Sweep.
- Bản chất của quá trình này là gửi một ICMP Echo Request đến máy chủ mà hacker đang muốn tấn công và mong đợi một ICMP Reply.
- Ngoài lệnh ping có sẵn trên Windows, còn có một số công cụ ping sweep như: Pinger, Friendly Pinger, Ping Pro…

Ports Scanning

- **Khái niệm**
  - Port scanning là một quá trình kết nối các cổng (TCP và UDP) trên một hệ thống mục tiêu nhằm xác định xem dịch vụ nào đang "chạy" hoặc đang trong trạng thái "nghe". Xác định các cổng nghe là một công việc rất quan trọng nhằm xác định được loại hình hệ thống và những ứng dụng đang được sử dụng.
- **Chức năng**
  - Xác định máy đang mở cổng nào.
  - Xác định hệ thống đang sử dụng dịch vụ nào.

Hoạt động Ports scanning

- Mỗi công cụ có cơ chế port scan riêng.
- Ví dụ: hoạt động của công cụ Nmap.
  - Nmap hỗ trợ nhiều kỹ thuật scan port như: TCP scan, SYN scan, Null scan, Windows scan, ACK scan…
  - Ví dụ TCP scan: kỹ thuật TCP scan tức là Nmap sẽ kiểm tra cổng trên hệ thống đích mở hay đóng bằng cách thực hiện kết nối TCP đầy đủ.
- **Một số công cụ Ports scanning**
  - Nmap
  - Super scan
  - Solarwinds

Hoạt động Ports scanning

Solarwinds

Tấn công xâm nhập (Access attack)

- Tấn công xâm nhập là một thuật ngữ rộng miêu tả bất kỳ kiểu tấn công nào đòi hỏi người xâm nhập lấy được quyền truy cập trái phép của một hệ thống bảo mật với mục đích thao túng dữ liêu, nâng cao đặc quyền.
- Tấn công truy nhập hệ thống: Là hành động nhằm đạt được quyền truy cập bất hợp pháp đến một hệ thống mà ở đó hacker không có tài khoản sử dụng.
- Tấn công truy nhập thao túng dữ liệu: Kẻ xâm nhập đọc, viết, xóa, sao chép hay thay đổi dữ liệu.

Tấn công từ chối dịch vụ (DoS)

- Về cơ bản, tấn công từ chối dịch vụ là tên gọi chung của cách tấn công làm cho một hệ thống nào đó bị quá tải không thể cung cấp dịch vụ, làm gián đoạn hoạt động của hệ thống hoặc hệ thống phải ngưng hoạt động.
- Tùy theo phương thức thực hiện mà nó được biết dưới nhiều tên gọi khác nhau. Khởi thủy là lợi dụng sự yếu kém của giao thức TCP (Transmision Control Protocol) để thực hiện tấn công từ chối dịch vụ DoS (Denial of Service), mới hơn là tấn công từ chối dịch vụ phân tán DDoS (Distributed DoS), mới nhất là tấn công từ chối dịch vụ theo phương pháp phản xạ DRDoS (Distributed Reflection DoS).

DoS (Denial of Service)

- Bom thư
- Đăng nhập liên tiếp
- Làm ngập SYN (Flooding SYN)
- Tấn công Smurf
- Ping of death
- Tear drop

SYN Attack

- Được xem là một trong những kiểu tấn công DoS kinh điển nhất. Lợi dụng sơ hở của thủ tục TCP khi "bắt tay ba bước", mỗi khi client muốn thực hiện kết nối với server thì nó thực hiện việc bắt tay ba bước thông qua các gói tin (packet)
- Bước 1: Client sẽ gửi gói tin (packet chứa SYN=1) đến máy chủ để yêu cầu kết nối.

SYN Attack

- Bước 2: khi nhận được gói tin này, server gửi lại gói tin SYN/ACK để thông báo cho client biết là nó đã nhận được yêu cầu kết nối và chuẩn bị tài nguyên cho việc yêu cầu này. Server sẽ dành một phần tài nguyên để nhận và truyền dữ liệu. Ngoài ra, các thông tin khác của client như địa chỉ IP và cổng (port) cũng được ghi nhận.
- Bước 3: cuối cùng client hoàn tất việc bắt tay ba bước bằng cách hồi âm lại gói tin chứa ACK cho server và tiến hành kết nối.

SYN Attack

- Do TCP là thủ tục tin cậy trong việc giao nhận nên trong lần bắt tay thứ hai, server gửi gói tin SYN/ACK trả lời lại client mà không nhận lại được hồi âm của client để thực hiện kết nối thì nó vẫn bảo lưu nguồn tài nguyên chuẩn bị kết nối đó và lặp lại việc gửi gói tin SYN/ACK cho client đến khi nhận được hồi đáp của client.
- Điểm mấu chốt ở đây là làm cho client không hồi đáp cho Server, và có càng nhiều, càng nhiều client như thế trong khi server vẫn lặp lại việc gửi packet đó và giành tài nguyên để chờ trong lúc tài nguyên của hệ thống là có giới hạn. Các hacker tấn công sẽ tìm cách để đạt đến giới hạn đó.

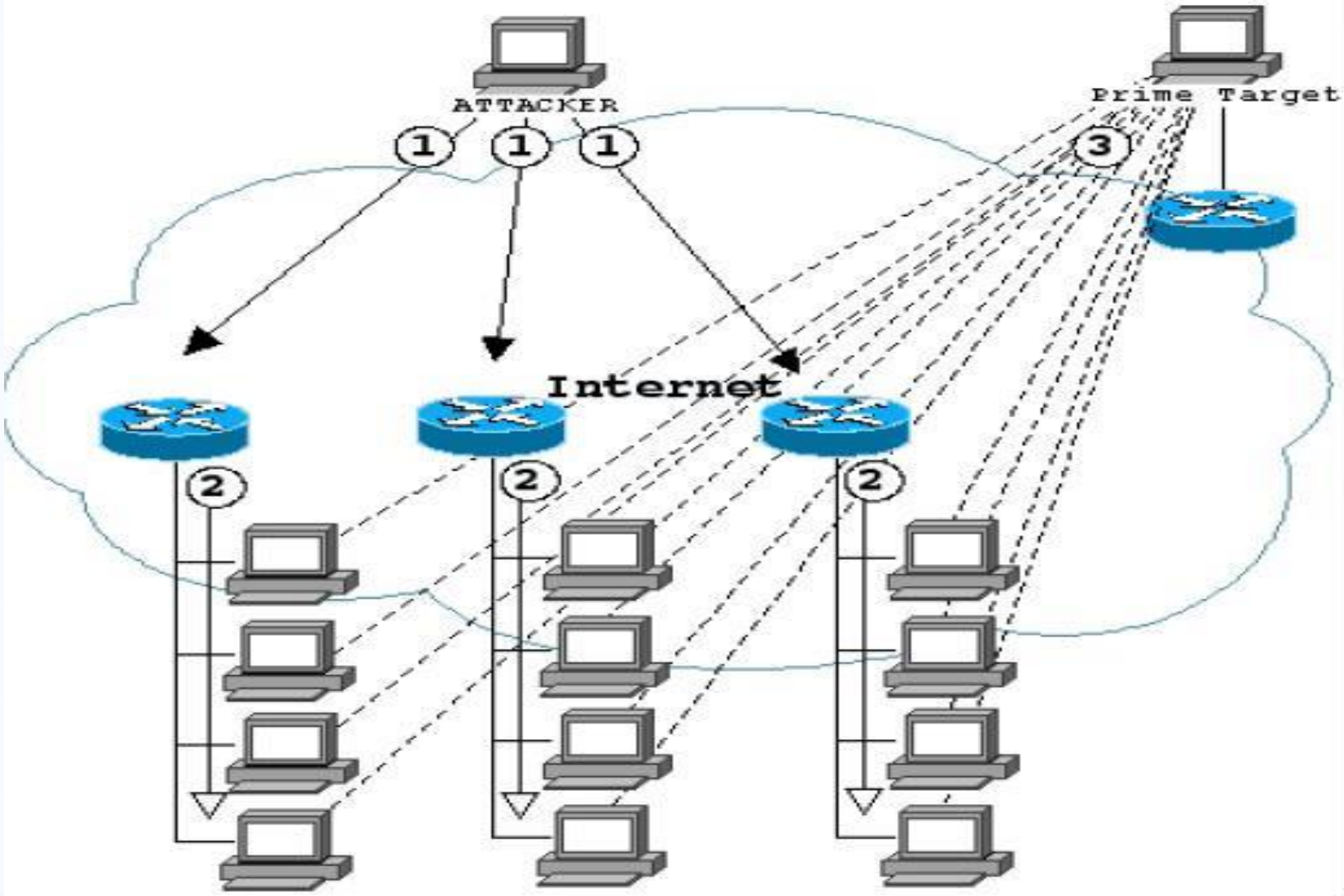
SYN Attack

- Thường, để giả địa chỉ IP, các hacker hay dùng Raw Sockets (không phải gói tin TCP hay UDP) để giả mạo hay ghi đè giả lên IP gốc của gói tin. Khi một gói tin SYN với IP giả mạo được gửi đến server, nó cũng như gói tin hợp lệ khác, server sẽ cấp vùng tài nguyên cho đường truyền này, đồng thời ghi nhận toàn bộ thông tin và gửi gói SYN/ACK ngược lại cho client.
- Vì địa chỉ IP của client là giả mạo nên sẽ không có client nào nhận được SYN/ACK packet này để hồi đáp cho máy chủ. Sau một thời gian không nhận được gói tin ACK từ client, server nghĩ rằng gói tin bị thất lạc nên lại tiếp tục gửi tiếp SYN/ACK, cứ như thế, các kết nối tiếp tục mở.

Flood attack

- Một kiểu tấn công DoS nữa cũng rất hay được dùng vì tính đơn giản của nó và vì có rất nhiều công cụ sẵn có hỗ trợ đắc lực cho kẻ tấn công là Flood Attack, chủ yếu thông qua các website.
- Về nguyên tắc, các website đặt trên máy chủ khi chạy sẽ tiêu tốn một lượng tài nguyên nhất định của máy chủ. Dựa vào đặc điểm đó, những kẻ tấn công dùng các phần mềm như smurf chẳng hạn để liên tục yêu cầu máy chủ phục vụ trang web đó để chiếm dụng tài nguyên.

Smurf attack



Smurf attack

- Thủ phạm sinh ra cực nhiều giao tiếp ICMP (ping) tới địa chỉ Broadcast của các mạng với địa chỉ nguồn là mục tiêu cần tấn công.
- Khi ping tới một địa chỉ là quá trình hai chiều – Khi máy A ping tới máy B máy B reply lại hoàn tất quá trình. Khi ping tới địa chỉ Broadcast của mạng nào đó thì toàn bộ các máy tính trong mạng đó sẽ Reply lại. Nhưng nếu thay đổi địa chỉ nguồn (máy C) và ping tới địa chỉ Broadcast của một mạng nào đó, thì toàn bộ các máy tính trong mạng đó sẽ reply lại vào máy C và đó là tấn công Smurf.

Smurf attack

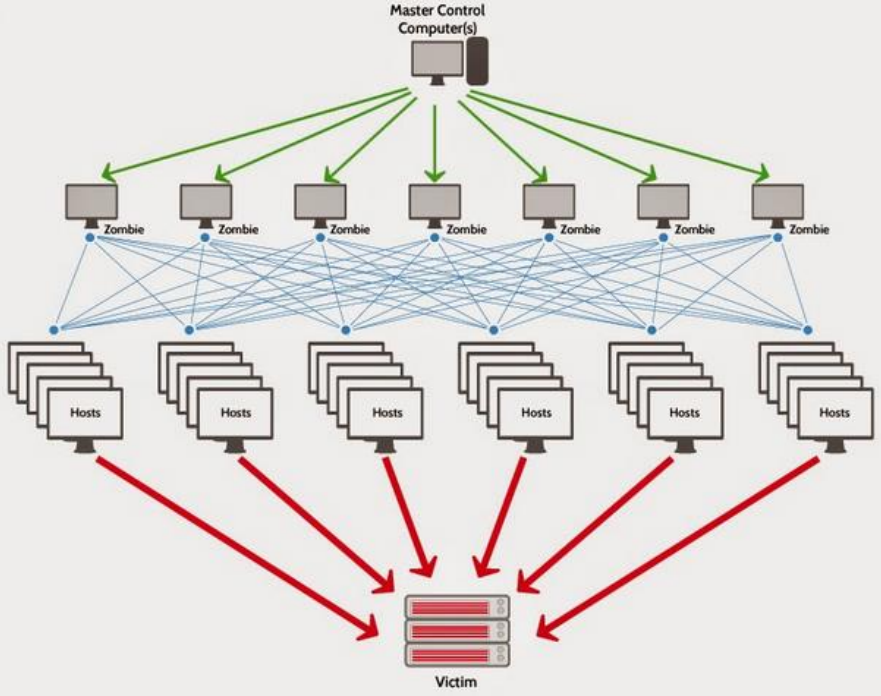
- Ping Of Death
- Tear Drop

Tấn công từ chối dịch vụ phân tán (DDoS)

- Xuất hiện vào năm 1999, so với tấn công DoS cổ điển, sức mạnh của DDoS cao hơn gấp nhiều lần.
- Hầu hết các cuộc tấn công DDoS nhằm vào việc chiếm dụng băng thông (bandwidth) gây nghẽn mạch hệ thống dẫn đến hệ thống ngưng hoạt động.
- Để thực hiện thì kẻ tấn công tìm cách chiếm dụng và điều khiển nhiều máy tính/mạng máy tính trung gian (đóng vai trò zombie) từ nhiều nơi để đồng loạt gửi ào ạt các gói tin với số lượng rất lớn nhằm chiếm dụng tài nguyên và làm tràn ngập đường truyền của một mục tiêu xác định nào đó.

DDoS

- DDoS (Distributed Denial of Service) - từ chối dịch vụ phân tán. Tấn công DDoS là nỗ lực làm sập một dịch vụ trực tuyến bằng cách làm tràn ngập nó với traffic từ nhiều nguồn.



DDoS

- Khái niệm:
  - Attacker: kẻ tấn công
  - Target: Mục tiêu
  - Client: Phần mềm điều khiển
  - Deamon: Phần mềm thực hiện tấn công.
  - Master: Máy tính chứa phần mềm client
  - Zombie: máy tính chứa phần mềm Deamon

DDoS

- Các giai đoạn của một cuộc tấn công kiểu DDoS:

Giai đoạn chuẩn bị

↓

Xác định mục tiêu và thời điểm

↓

Phát động tấn công

↓

Xóa dấu vết (nếu cần)

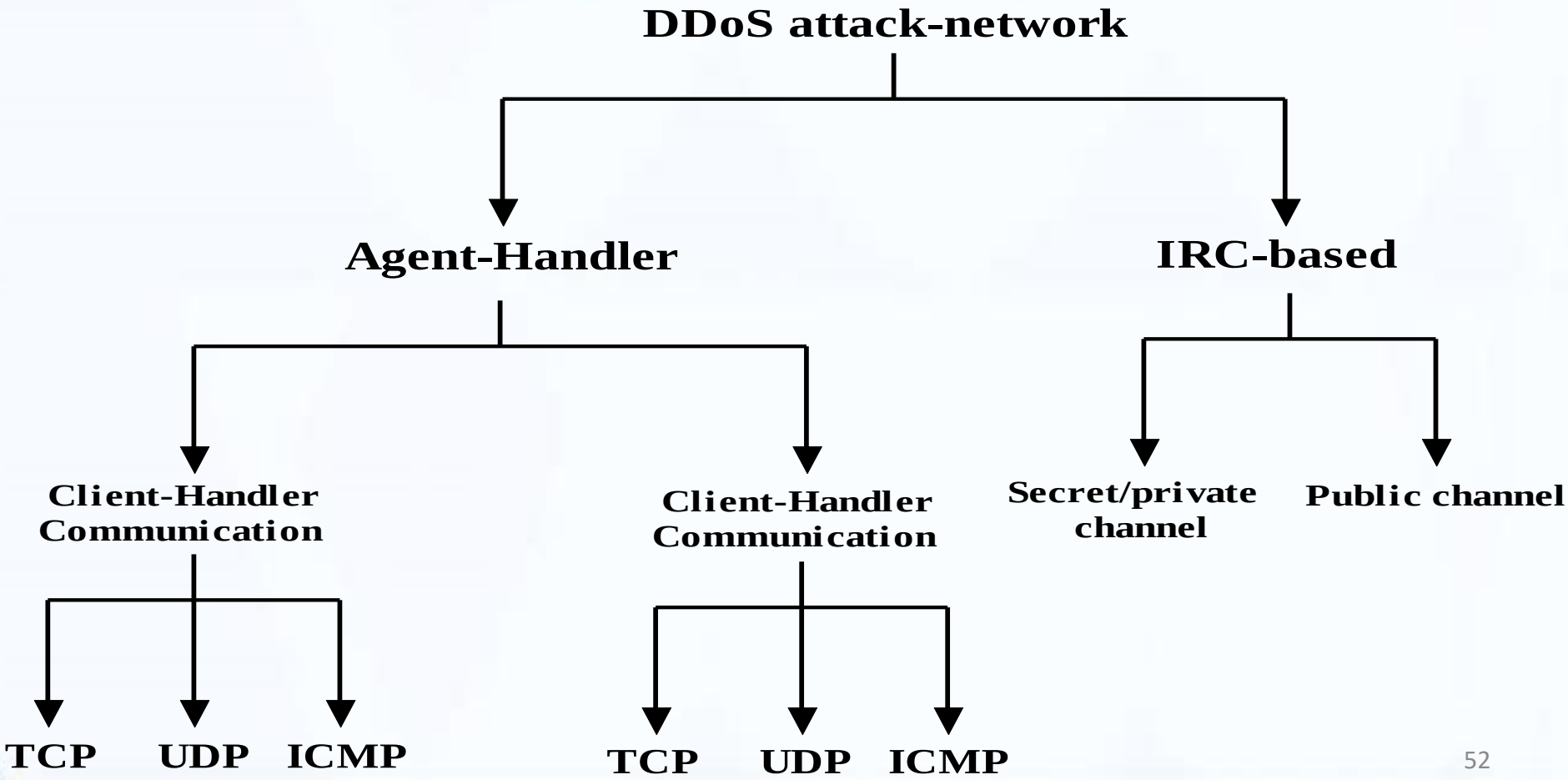
DDoS

Các giai đoạn thực hiện:

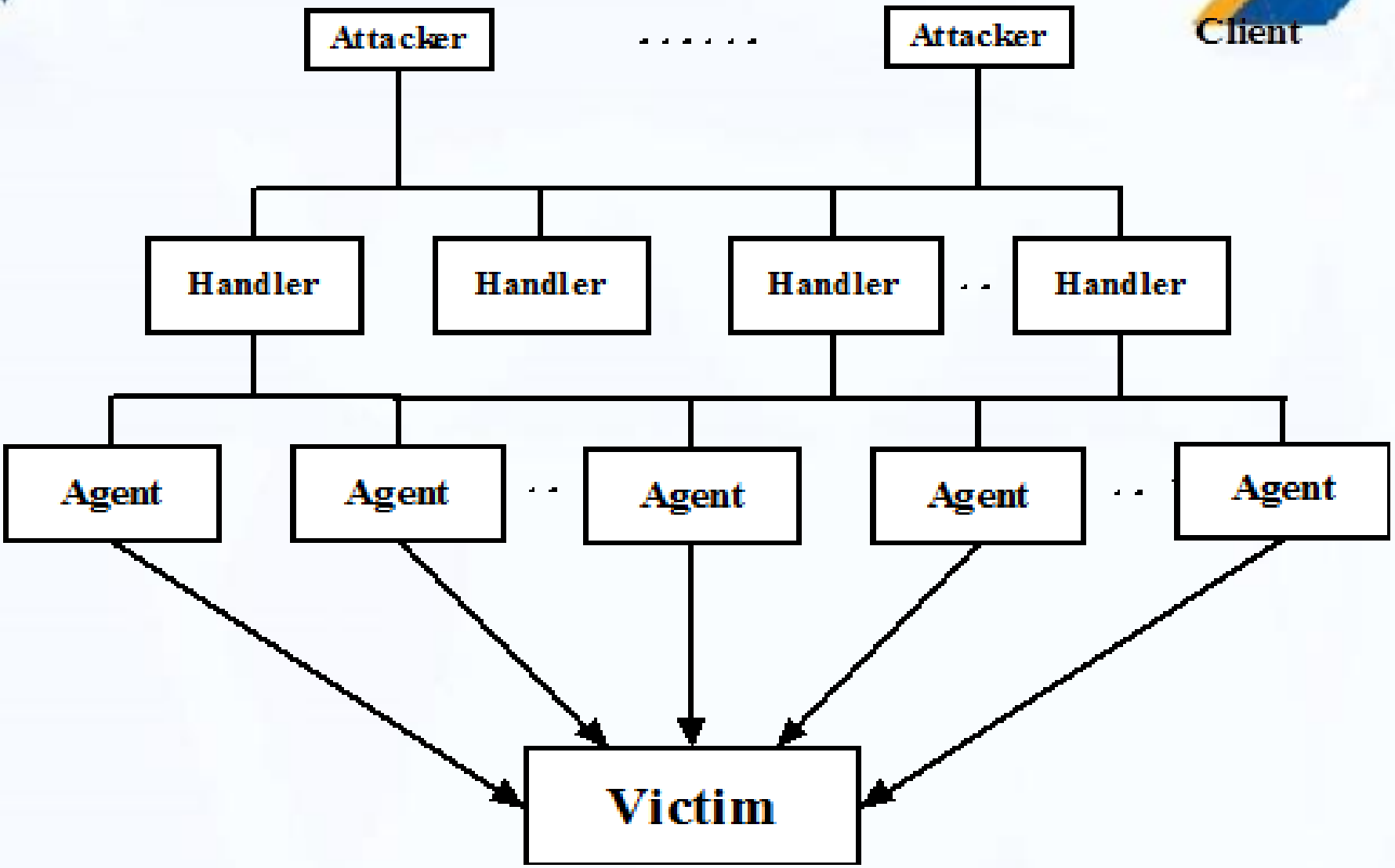
Giai đoạn chuẩn bị	– Chiếm quyền điều khiển. – Cài đặt phần mềm – Ẩn mình.
Xác định mục tiêu và thời điểm	– Xác định mục tiêu tấn công và thời điểm thực hiện tấn công.
Phát động tấn công	– "ra lệnh" tấn công target đến các Master và Zombie.
Xóa dấu vết	– Thời gian thực hiện nhanh.

MỘT SỐ DẠNG DDoS

- *Mô hình Agent-Handler và Mô hình IRC-based.*



Mô hình Agent-Handler



Mô hình Agent-Handler

- Theo mô hình này, attack-network gồm 3 thành phần: Agent, Client và Handler
- Client: Là software cơ sở để hacker điều khiển mọi hoạt động của attack-network
- Handler: Là một thành phần software trung gian giữa Agent và Client
- Agent: Là thành phần software thực hiện sự tấn công mục tiêu, nhận điều khiển từ Client thông qua các Handler

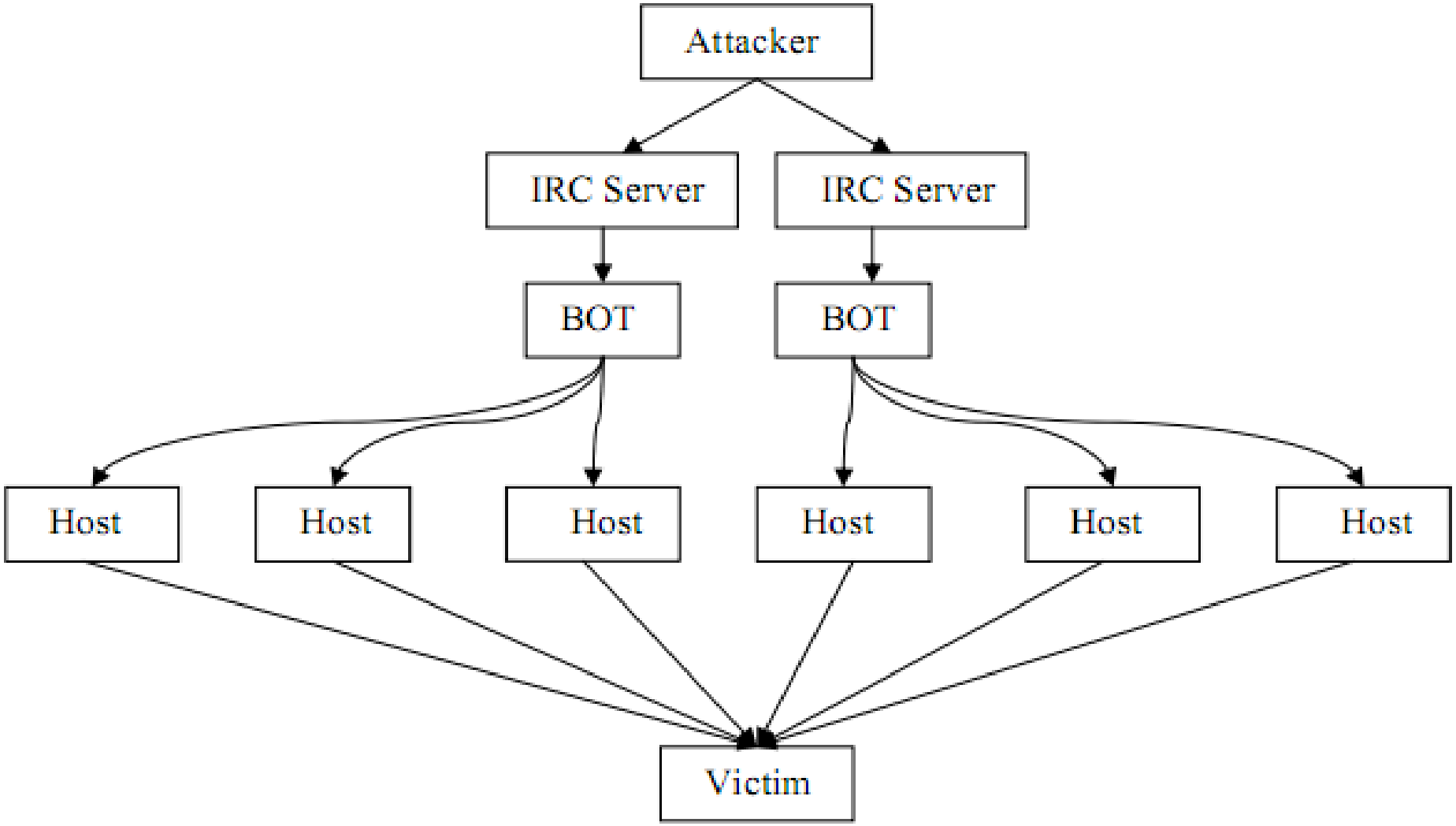
Mô hình IRC – Based

- Internet Relay Chat (IRC) là một hệ thống online chat multiuser, IRC cho phép user tạo một kết nối đến đa điểm (multipoint) đến nhiều user khác và chat thời gian thực.
- Kiến trúc của mạng IRC (IRC network) bao gồm nhiều IRC server trên khắp internet, giao tiếp với nhau trên nhiều kênh (channel).
- IRC network cho phép user tạo ba loại kênh: public, private và serect.

Mô hình IRC – Based

- Public channel: Cho phép user của kênh đó thấy IRC name và nhận được message của mọi user khác trên cùng kênh.
- Private channel: Được thiết kế để giao tiếp với các đối tượng cho phép. Không cho phép các user không cùng channel thấy IRC name và message trên channel. Tuy nhiên, nếu user ngoài channel dùng một số lệnh channel locator thì có thể biết được sự tồn tại của private channel đó.
- Secrect channel: Tương tự private channel nhưng không thể xác định bằng channel locator.

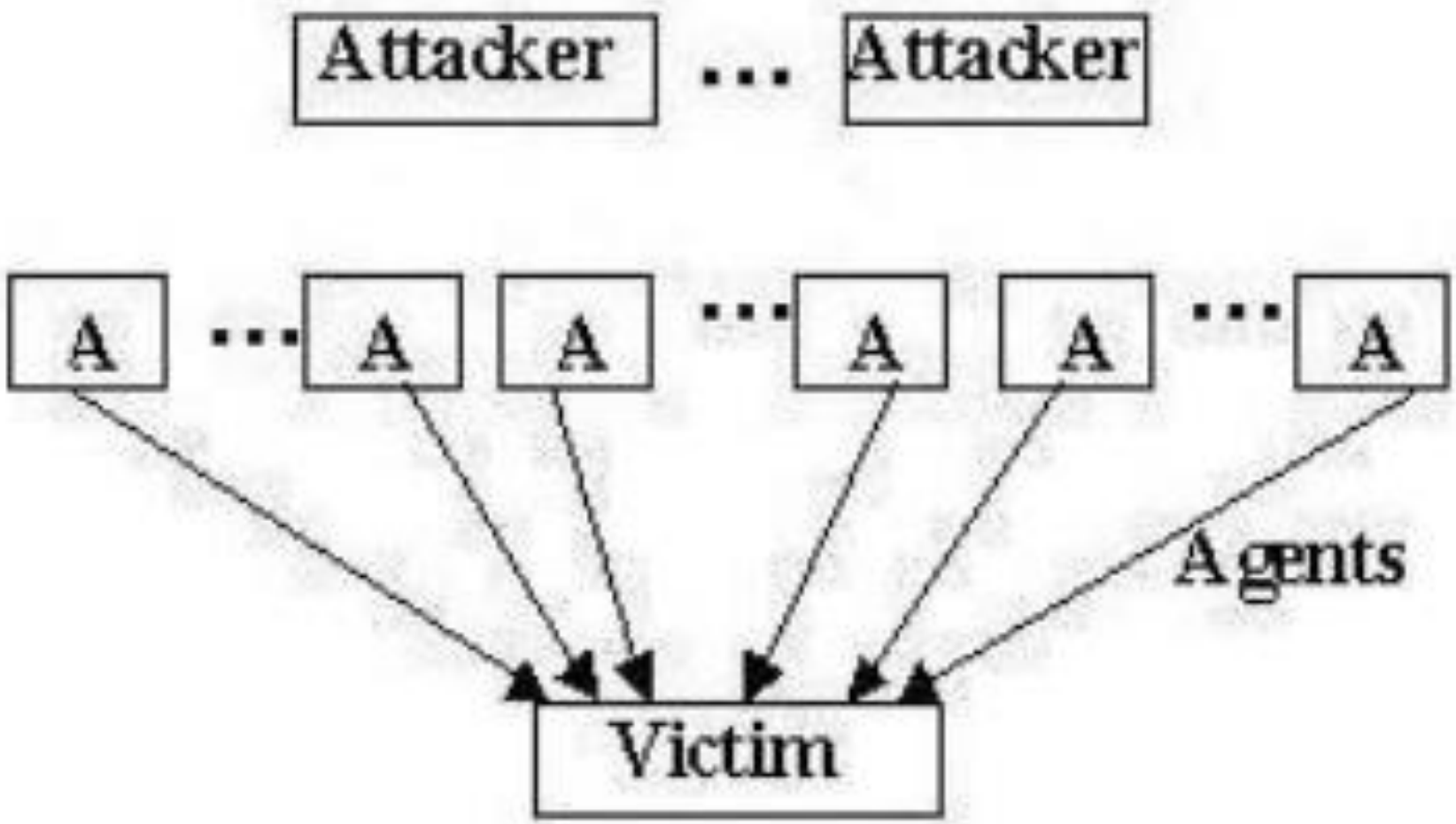
Mô hình IRC – Based



Mô hình IRC – Based

- IRC – Based network cũng tương tự như Agent – Handler network nhưng mô hình này sử dụng các kênh giao tiếp IRC làm phương tiện giao tiếp giữa Client và Agent (không sử dụng Handler).
- Sử dụng mô hình này, attacker còn có thêm một số lợi thế khác như:
  - Các giao tiếp dưới dạng chat message làm cho việc phát hiện chúng là vô cùng khó khăn.
  - IRC traffic có thể di chuyển trên mạng với số lượng lớn mà không bị nghi ngờ.
  - Không cần phải duy trì danh sách các Agent, hacker chỉ cần log on vào IRC server là đã có thể nhận được report về trạng thái các Agent do các channel gửi về.
  - IRC cũng là một môi trường file sharing tạo điều kiện phát tán các Agent code lên nhiều máy khác.

Mô hình Scattered



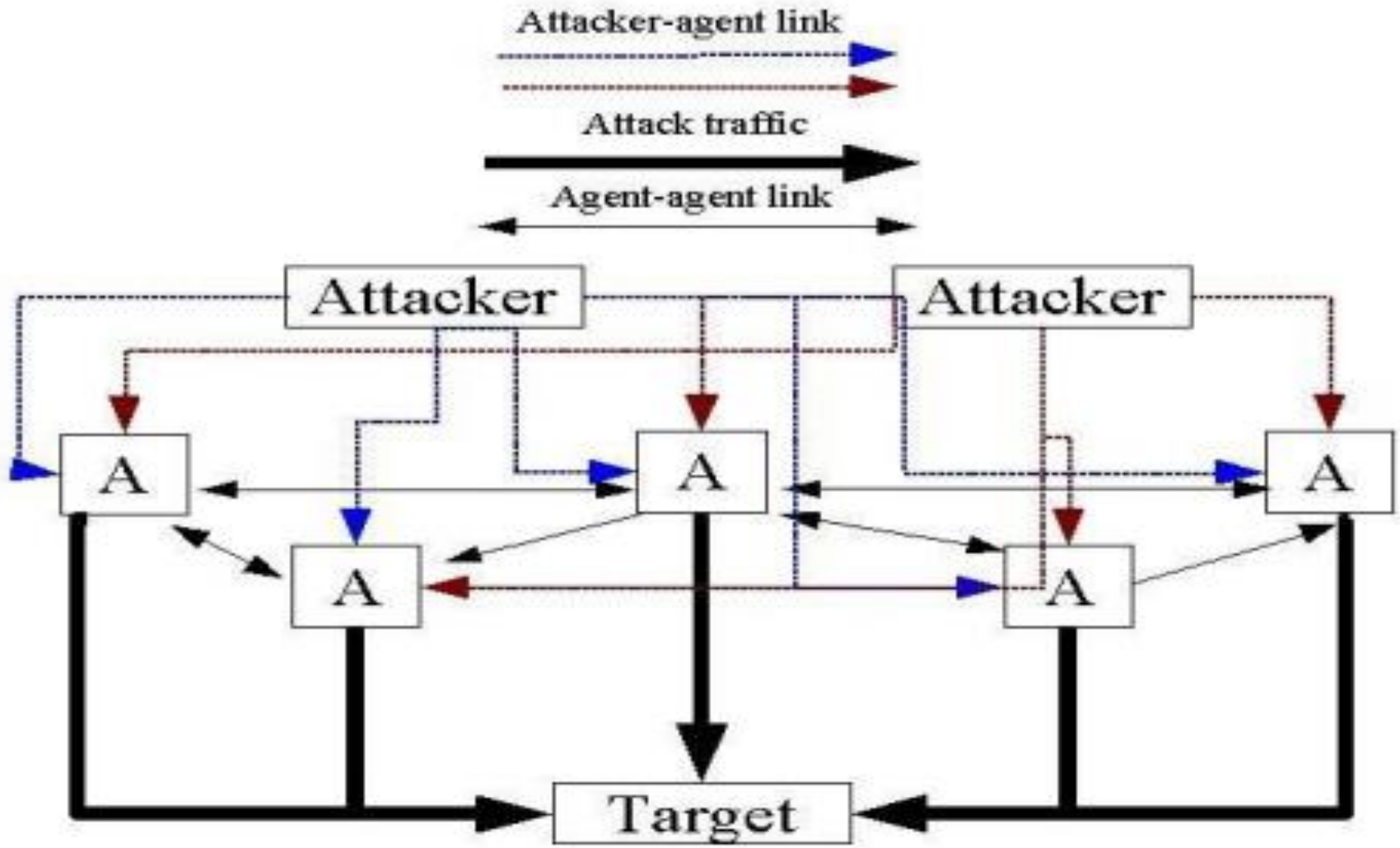
Mô hình Scattered

- Mô hình tán xạ khác với các mô hình DDoS khác đó là nó không có bất kỳ sự liên lạc đầy đủ của các node mạng phân tán có nghĩa là các node không biết nhau một cách đầy đủ.
- Mặc dù Attacker thường không biết được vị trí của các node. Topo của các node là tự ý được xác định và chỉ được liên kết tới đích thông qua traffic tấn công cũng có nghĩa là nó không sinh ra các traffic nào khác.
- Theo nghĩa khác mạng DDOS của mô hình Scattered được xây dựng có sự độc lập của các Agent.

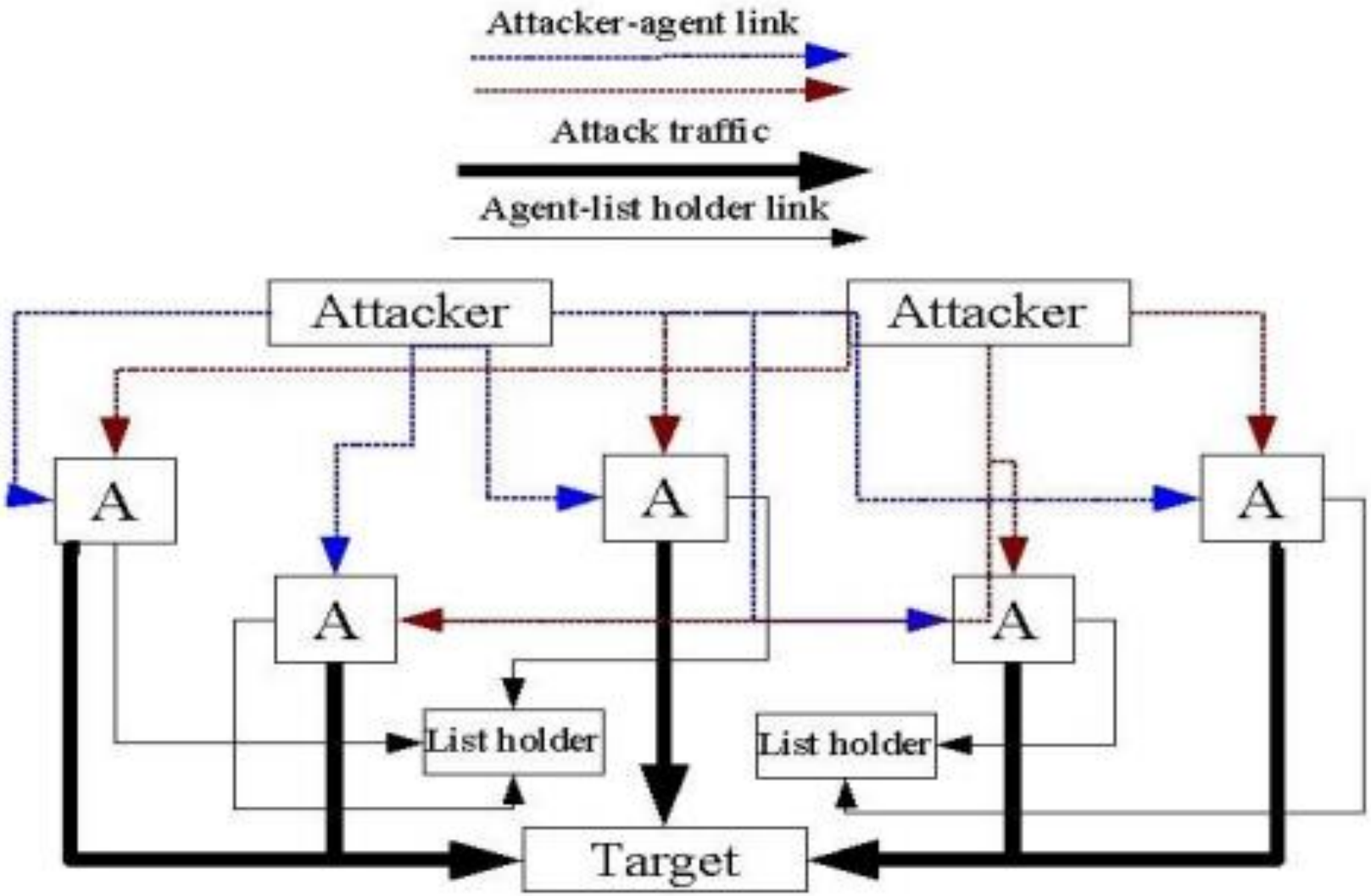
Mô hình peer to peer

- Mô hình này có nhiều đặc điểm thuận lợi hơn so với các mô hình trước.
- Mô hình này có nguyên lý của mạng peer to peer.
- Một mạng phân tán có cấu trúc được gọi là mạng Peer to peer nếu những người tham gia chia sẻ một phần tài nguyên phần cứng của họ (sức mạnh xử lý, khả năng lưu trữ, khả năng kết nối mạng, máy in).

Mô hình pure peer to peer



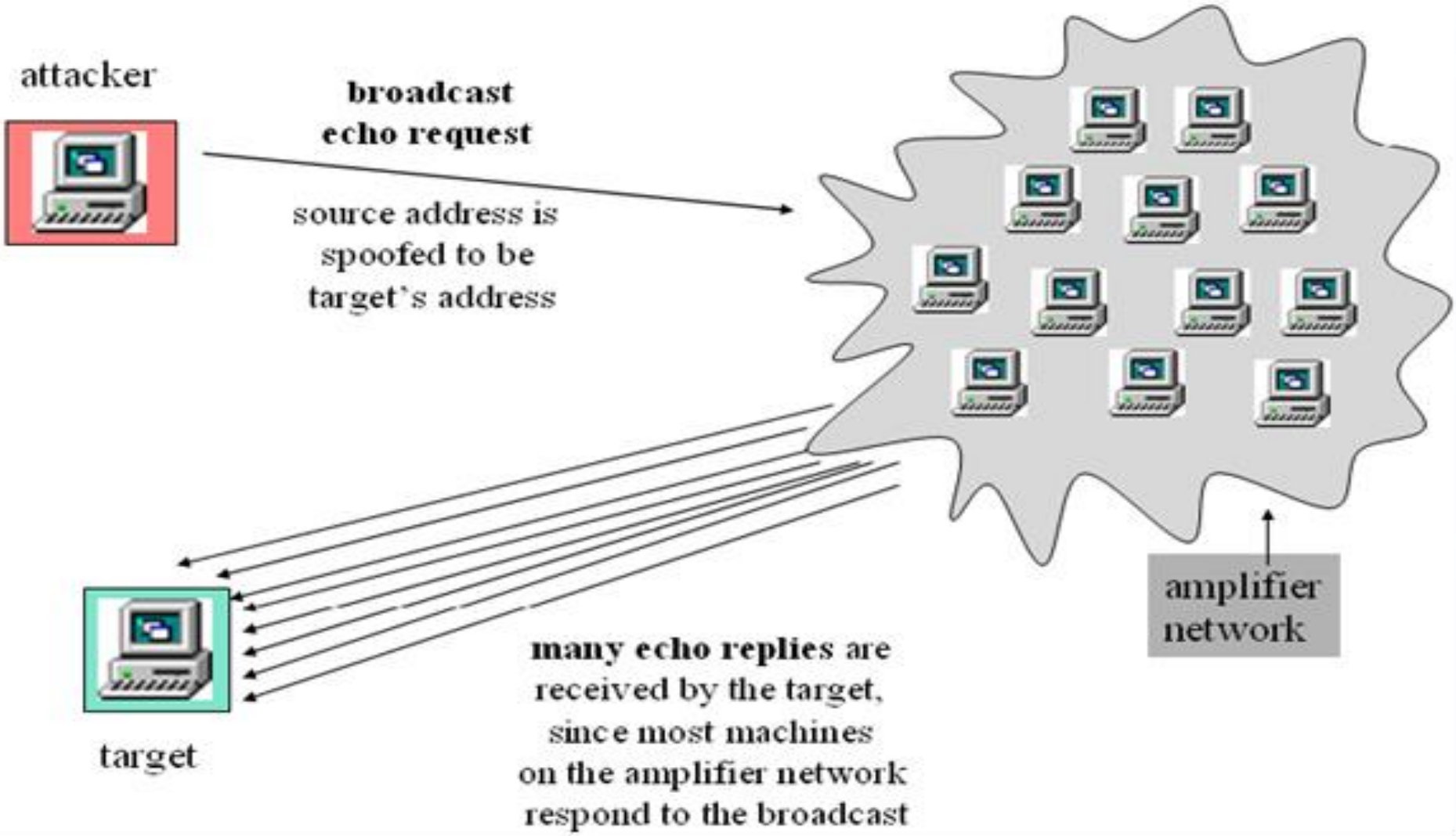
Mô hình hybrid peer to peer



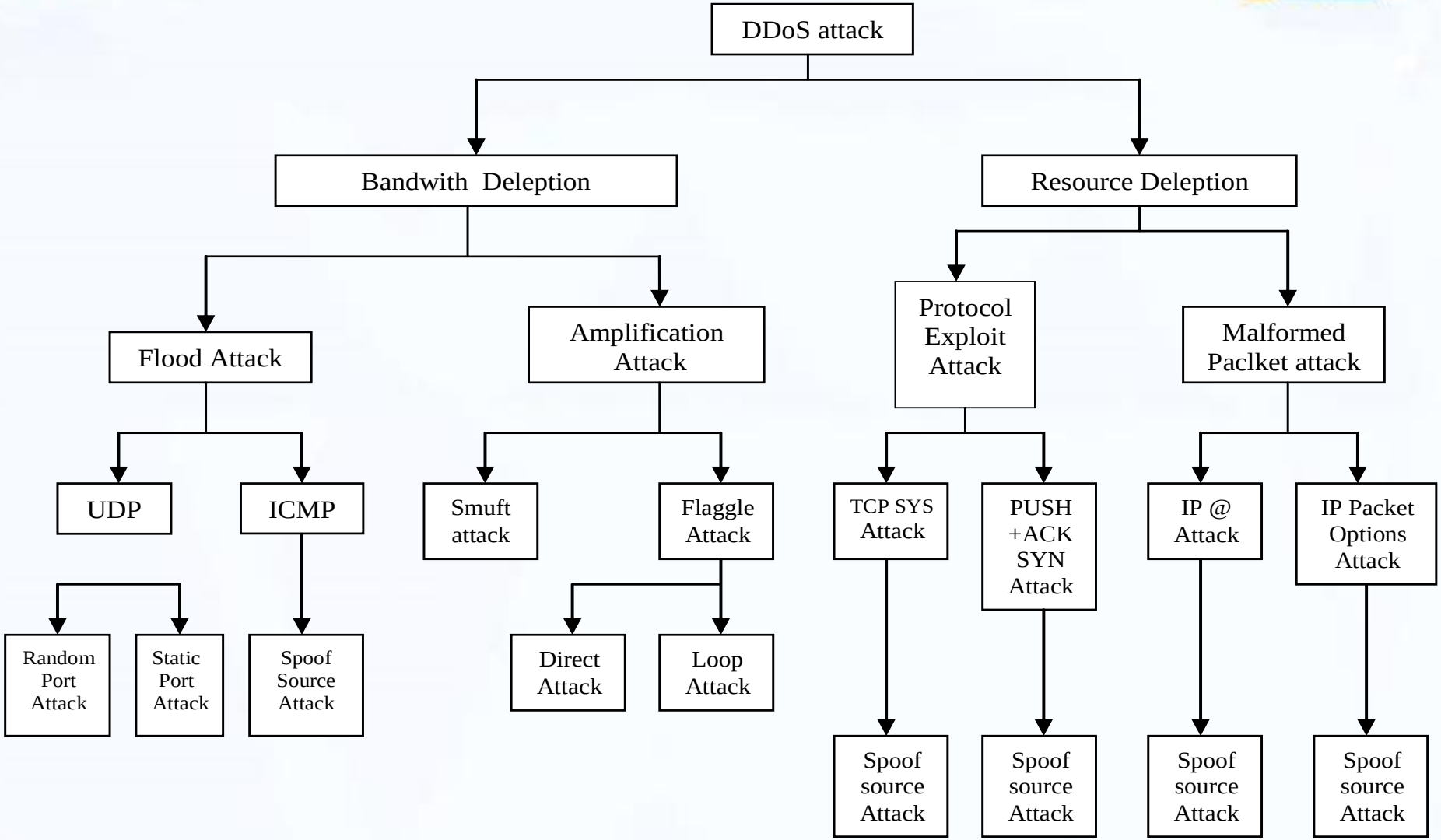
Bandwith Depletion Attack

- Được thiết kế nhằm làm tràn ngập mạng mục tiêu với những traffic không cần thiết, với mục địch làm giảm tối thiểu khả năng của các traffic hợp lệ đến được hệ thống cung cấp dịch vụ của mục tiêu.
- *Flood attack*: Điều khiển các Agent gửi một lượng lớn traffic đến hệ thống dịch vụ của mục tiêu, làm dịch vụ này bị hết khả năng về băng thông.
- *Amplification attack*: Điều khiển các agent hay Client tự gửi message đến một địa chỉ IP broadcast, làm cho tất cả các máy trong subnet này gửi message đến hệ thống dịch vụ của mục tiêu. Phương pháp này làm gia tăng traffic không cần thiết, làm suy giảm băng thông của mục tiêu.

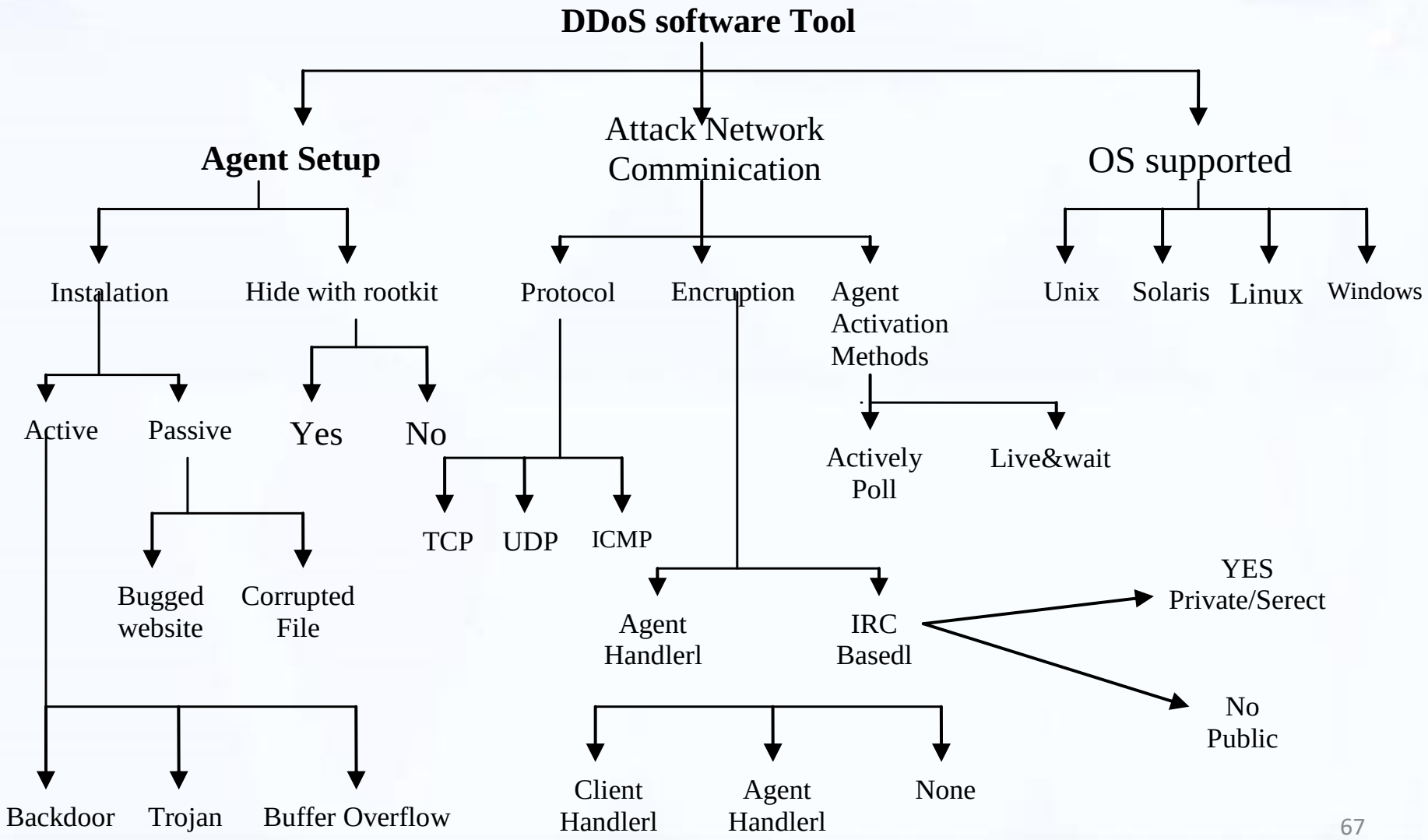
Amplification Attack



Phân loại tấn công kiểu DDOS



Một số đặc tính của công cụ DDoS



Một số hình thức DDoS

Hình thức	Nguyên lý
UDP Flood	Lợi dụng đặc điểm của giao thức UDP
SYN Flood	Lợi dụng đặc điểm của giao thức TCP
Ping of Death (Tear Drop, Bonk)	Sử dụng ICMP
Repflected Attack	Giả mạo IP nạn nhân gửi tin đến nhiều ip khác.
Peer-to-Peer Attacks	Dựa vào đặc điểm của kết nối P2P
Slowloris	Tương tự như SYN Flood nhưng dung giao thức HTTP (APP layer)
Degradation of Service Attacks (Suy giảm dịch vụ)	Sử dụng zombies chiếm lưu lượng làm chậm thời gian đáp ứng dịch vụ.
Application Level Attacks	Tấn công lỗ hổng ứng dụng
Zero day DDoS	Tấn công lỗ hổng chưa phát hiện hoặc chưa được fix
Multi-vector Attacks	Tấn công = nhiều hình thức

PHÒNG CHỐNG

- Bảo vệ hệ thống và bảo vệ máy tính khỏi các cuộc tấn công bởi các phần mềm độc hại: Tường lửa, Anti Virus, Port Sercurity … đảm bảo hoạt động liên tục của các ứng dụng này.
- Nắm rõ kiến trúc hạ tầng HTTT mình đang quản lý.
- Xây dựng hệ thống và chính sách đảm bảo an ninh mạng từ 2 chiều từ bên trong và từ bên ngoài.
- Xây dựng hệ thống máy chủ có khả năng chịu tải tốt.

PHÒNG CHỐNG

- Hiểu rõ các loại tấn công.
- Sử dụng các công cụ rà quét lỗ hổng, phần mềm và thiết bị theo dõi "sức khỏe" mạng và máy tính.
- Sử dụng các công cụ phát hiện và ngăn chặn để hạn chế truy cập bằng cách giới hạn request, session, khối lượng gói tin, thời gian truy cập … trong thời gian cố định nào đó.
- Lập các phương án xử lý khi xảy ra sự cố bị tấn công.
- Thực hiện các chính sách về nhân sự, tài chính, đánh giá hiệu quả của việc phòng chống DDoS